

Manual 32 — Implementação controlada FFIEC

****Idioma:**** Português do Brasil (pt-BR)

****Linha de base controlada:**** materiais ativos do FFIEC Information Technology Examination Handbook e overlays aplicáveis das agências membros, reverificados em 31 de agosto de 2026.

****Limite:**** o Handbook FFIEC é orientação interagencial de exame. Não é uma lei federal autônoma e não substitui leis, regulamentos ou ordens vinculantes, achados supervísórios específicos de uma instituição ou análise jurídica/regulatória qualificada. O FFIEC Cybersecurity Assessment Tool (CAT) foi descontinuado em 31 de agosto de 2025 e não é usado como linha de base atual.

Chapter 01 — Propósito, escopo e hierarquia controlada de fontes

Use os booklets vigentes do FFIEC IT Handbook como fontes de orientação de exame e mantenha referências separadas para leis, regulamentos, regras/ordens de agências, declarações supervísórias e compromissos específicos. Exemplos internos não são desenhos aprovados por reguladores.

Chapter 02 — Tipo de instituição, charter, regulador e aplicabilidade

Mantenha matriz com tipo de instituição, charter, regulador federal primário, regulador estadual quando aplicável, entidades, serviços, papéis como technology service provider e overlays relevantes. Não infira requisitos de exame a partir de rótulo genérico.

Chapter 03 — Modelo de governança FFIEC e supervisão do board

Converta conceitos de governança FFIEC em responsabilidades definidas do board/alta gestão, reporting, escalonamento, recursos, aprovação de políticas e challenge. Preserve evidência de supervisão informada de risco IT/cibernético.

Chapter 04 — Integração com enterprise risk management

Integre risco IT e cibernético com ERM por taxonomia, apetite/tolerância, proprietários, escalonamento, concentração, risco emergente e gatilhos de mudança. Preserve diferenças entre orientação supervísória e requisitos vinculantes.

Chapter 05 — Governança do information-security program

Mantenha programa de segurança da informação ligado a risk assessment, governança, controles, operações, incident response, testes e melhoria. Mapeie separadamente Interagency Information Security Standards e requisitos específicos de agências.

Chapter 06 — Governança de arquitetura e infraestrutura IT

Mantenha arquitetura atual de sistemas, plataformas, redes, cloud, data flows, dependências, resiliência, trust boundaries e terceiros. Decisões devem ser avaliadas por risco, aprovadas, rastreáveis e disponíveis para exame no nível apropriado.

Chapter 07 — Operações de tecnologia e service management

Governe produção por proprietários, monitoramento, processos, capacidade, disponibilidade, eventos, problemas, service levels, backup, operações privilegiadas e registros. A evidência deve demonstrar operação sustentada, não apenas intenção de política.

Chapter 08 — Governança de desenvolvimento, aquisição e manutenção

Aplique o booklet FFIEC Development, Acquisition, and Maintenance de 2024 a planejamento, aquisição, SDLC, projeto, manutenção, supply-chain risk, segurança, resiliência e ciclo de vida. Separe responsabilidades internas e de fornecedores.

Chapter 09 — Change e configuration management

Controle mudanças por autorização, risco, testes, segregação de funções, emergency changes, baselines, evidência de deployment, rollback e post-implementation review. Vincule mudanças falhas/não autorizadas a issue management.

Chapter 10 — Inventário de ativos e ciclo de vida tecnológico

Mantenha inventários de hardware, software, aplicações, infraestrutura, cloud, dados, dependências, proprietários, criticidade, suporte e ciclo de vida. Identifique tecnologia unsupported/end-of-life e documente tratamento, migração ou exceção aprovada.

Chapter 11 — Identity governance e administração de acesso

Defina ciclo de identidade, provisioning, papéis, aprovação, least privilege, recertificação, transferência/desligamento, service accounts, usuários externos e exceções. Reconcilie diretórios e entitlements com fontes autoritativas.

Chapter 12 — Authentication e privileged access

Use autenticação baseada em risco e controles reforçados para acesso privilegiado, remoto, de alto risco ou sensível. Documente MFA/equivalentes, PAM, proteção de credenciais, monitoramento, emergência e compensating controls.

Chapter 13 — Classificação de dados, proteção e criptografia

Classifique informação por sensibilidade, requisitos legais, impacto, obrigações ao cliente e retenção. Aplique acesso, criptografia, key management, transferência, masking, descarte, backup e monitoramento conforme risco e obrigações.

Chapter 14 — Segurança de rede, endpoint e infraestrutura

Implemente controles em segmentação, firewalls, remote access, endpoint protection, hardening, wireless, e-mail/web, interfaces administrativas, cloud networking e infraestrutura. Mantenha diagramas, baselines, exceções e monitoramento.

Chapter 15 — Logging, monitoring, detecção e security analytics

Defina fontes de eventos, centralização, retenção, alertas, tuning, escalonamento, responsabilidades, investigações e validação de cobertura. O desenho deve refletir ativos críticos, ameaças, obrigações e perfil de risco.

Chapter 16 — Vulnerability, patch e exposure management

Opere descoberta, avaliação, priorização, patching, remediação de configuração, exposição externa, exceções e verificação. Gerencie exposições vencidas por aceitação documentada e controles compensatórios.

Chapter 17 — Software seguro e controles de aplicações

Aplique desenho seguro, requisitos, coding, code review, testing, dependência/SBOM ou controles equivalentes quando apropriados, secrets management, release, manutenção e remediação. Separe controles da instituição de responsabilidades do fornecedor.

Chapter 18 — Cloud, virtualização e tecnologia emergente

Avalie cloud, SaaS, containers, virtualização, IA, automação, APIs e outras tecnologias por arquitetura, dados, identidade, resiliência, terceiros, concentração, exit, segurança e compliance. A assurance do fornecedor não elimina accountability institucional.

Chapter 19 — Supervisão de terceiros e technology service providers

Mantenha due diligence, contratos, requisitos de segurança, revisão de desempenho/assurance, acesso, incidentes, resiliência, subcontratados, encerramento e exit. Aplique separadamente requisitos legais ou de agência para TSP.

Chapter 20 — Outsourcing e risco de concentração

Avalie concentração operacional, geográfica, sistêmica, cloud, fornecedor, plataforma, habilidades, dados e recuperação. Defina tolerância, contingência, alternativas, viabilidade de exit, escalonamento e monitoramento.

Chapter 21 — Cybersecurity incident response e escalonamento

Mantenha governança de incidentes para detecção, triage, severidade, contenção, erradicação, recuperação, evidência, comunicações, análise legal/regulatória, impacto, terceiros, lições e remediação. Teste decisões e dependências.

Chapter 22 — Notificação regulatória e decisões de overlays de agência

Mantenha matriz de obrigações por regulador, norma, tipo de evento, limiar, prazo, método e proprietário. Preserve fatos, timestamps, análise, autoridade, filing e suplementos; severidade interna não substitui trigger legal.

Chapter 23 — Business continuity e disaster recovery

Use o FFIEC Business Continuity Management vigente para continuidade empresarial, recovery tecnológico, comunicações, dependências, crise e testes. Vincule BIA, objetivos, planos, testes, achados e remediação a serviços críticos.

Chapter 24 — Operational resilience e scenario testing

Teste cenários severos, porém plausíveis, envolvendo cyber, tecnologia, terceiros, instalações, pessoas, dados e dependências externas. Defina objetivos, premissas, decisões, targets, lições, proprietários e melhorias.

Chapter 25 — Backup, recovery e restoration assurance

Governe escopo, frequência, proteção immutable/offline quando apropriada, acesso, criptografia, retenção, monitoramento, restauração, dependências e testes. Demonstre recoverability por restores bem-sucedidos e remediação de falhas.

Chapter 26 — Interfaces de segurança física e ambiental

Coordene IT/cyber com instalações, energia, cooling, incêndio, physical access, vigilância, data centers, monitoramento ambiental e sites alternativos. Identifique responsabilidades compartilhadas e evidência de instalações próprias/terceirizadas.

Chapter 27 — Awareness e treinamento baseado em papel

Forneça awareness básico e treinamento para usuários privilegiados, developers, admins, incident responders, executivos, board, third-party managers e papéis relevantes. Mantenha conteúdo, população, conclusão, exceções, efetividade e mudanças por risco.

Chapter 28 — Testes independentes, auditoria e assurance

Defina assurance independente conforme risco, lei e expectativas supervisórias. Preserve escopo, independência, método, população/amostra, achados, ratings, resposta, validação de remediação e limites de confiança em relatórios de terceiros.

Chapter 29 — Examination readiness e gestão de evidência

Mantenha índice de evidência ligando solicitações a políticas, procedimentos, inventários, assessments, governança, controles, testes, issues e proprietários. Forneça evidência atual e reconciliada e explique gaps ou artefatos superados.

Chapter 30 — Issue management, remediação e aceitação de risco

Gerencie issues de exame, auditoria, controle, risco, incidentes e testing com fonte, severidade, causa, proprietário, data, controles interinos, validação e encerramento. Aceitação de risco não pode anular obrigações vinculantes ou compromissos supervisórios.

Chapter 31 — Métricas, reporting, rastreabilidade supervisória e melhoria

Defina métricas com fórmula, fonte, população, frequência, proprietário, threshold, exclusões e ação. O reporting deve conectar riscos/issues a decisões e remediação; maturity scores ou contagens não comprovam compliance.

Chapter 32 — Reverificação de fontes e roadmap de implementação

Antes de cada release, revalide FFIEC IT Handbook, orientações/regras das agências, requisitos legais e desenvolvimentos de exame. Confirme explicitamente que o CAT descontinuado permanece não vigente e avalie sucessores, revisões de booklets e mudanças regulatórias.

Conjunto mínimo de evidência

Mantenha, conforme aplicável: matriz regulador/aplicabilidade; supervisão board/gestão; security program; risk assessment; arquitetura/inventário; acessos; authentication/PAM; dados; rede/endpoint; logging; vulnerabilidades/patch; desenvolvimento/mudança; cloud/emerging tech; TSP/outsourcing/concentration; incidentes/notificações; BCM/DR/restores; instalações; training; assurance independente; índice de exame; issues/risk acceptance; métricas/reporting; e verificação de fontes.